

Insider Threat Incident Response Playbook — Aviation SOC

Playbook Name: IRP-AV-HT-001 — High-Risk Insider Threat: Data Exfiltration / Sabotage Preparation

Version: 1.0

Date: 2025-06-02

Author: SOC Incident Response Lead

Status: Approved

Applicable Alert Types

Alert Source	Rule / Condition	Risk Threshold
Risk Scoring Engine	Cumulative score $\geq$ 60 (high) from <code>risk_scoring.py</code>	$\geq$ 60
Off-Hours Badge Access	<code>badge_logs</code> : hour 22-06, <code>shift_scheduled</code> = False, sensitive door	$\geq$ 25 (cumulative with below)
Bulk Data Download	<code>crew_portal_logs</code> : <code>action</code> = download, (<code>record_count</code> > 100 OR <code>bytes_transferred</code> > 500 MB), <code>record_type</code> in (PassengerManifest, SecurityProtocol)	30
Unusual VPN Login	<code>vpn_logs</code> : <code>geo_country</code> $\in$ {RU, CN, IR, KP, SY} OR mismatch with <code>typical_country</code>	15
Maintenance Tampering	<code>maintenance_logs</code> : <code>action</code> $\in$ {override_sensor, disable_alarm, edit_log}, <code>component</code> $\in$ {Engine, FuelSystem, FlightControls}, <code>work_order_valid</code> = False	30
Cargo Weight Anomaly	<code>cargo_logs</code> : <code>action</code> = edit_manifest, <code>weight_kg</code> delta > 20 kg on same <code>cargo_id</code> within 1 hour	20

Triggering Scenario (from PDFs)

A ground-staff employee (RampAgent, BaggageHandler, Mechanic, Fueller) generates a **high-risk alert (score ≥ 60)** through a combination of:

1. **Off-hours badge access** to CargoArea or MaintenanceHangar between 22:00 and 06:00 with no shift scheduled.
2. **Bulk download** of PassengerManifest or SecurityProtocol records from the crew portal.
3. (Optional) **VPN login** from a foreign country outside their typical pattern.

Real-world analogues:

- 2018 Horizon Air Q400 ground-crew theft (unauthorised flight access).
 - 2019 American Airlines mechanic sabotage (foam inserted into navigation system).
 - Multiple TSA cases of baggage handlers smuggling firearms via cargo-manifest manipulation.
-

1. Alert Triage & Validation

Goal: Confirm the alert is not a false positive.

Target: ≤ 15 minutes.

Step 1.1 — Open the Alert

1. Open the SIEM (Wazuh / Elastic) alert for the triggered event.
2. Record the following fields immediately:
 - **Alert ID:** (from SIEM)
 - **Employee ID:** `risk_summary.employee_id`
 - **Role:** `risk_summary.role`
 - **Risk Score:** `risk_summary.total_score`
 - **Contributing Events:** `risk_summary.event_type`
 - **Time Window:** `risk_summary.date` (or range for compound events)
 - **Triggering Log Sources:** `badge_logs`, `crew_portal_logs`, `vpn_logs`, etc.

Step 1.2 — Verify Off-Hours Badge Access

Query the `badge_logs` table for the employee on the alert date:

```
-- SIEM query (pseudocode)
SELECT timestamp, door_location, granted
FROM badge_logs
WHERE employee_id = '<EMP_ID>'
      AND hour_of_day IN (22,23,0,1,2,3,4,5)
ORDER BY timestamp;
```

Checks:

- ☐ Was the door in a sensitive zone? (CargoArea, DataCenter, MaintenanceHangar)
- ☐ Was `shift_scheduled = False`? (Cross-reference with `employee_table.shift_start / shift_end`.)
- ☐ If `shift_scheduled = True` → probable false positive → document and downgrade alert to **low**.
- ☐ If `shift_scheduled = False` but employee claims to be on-call → verify with supervisor.

Step 1.3 — Verify Bulk Download

Query the `crew_portal_logs`:

```
SELECT timestamp, record_type, record_count, bytes_transferred
FROM crew_portal_logs
WHERE user = '<EMP_ID>'
      AND action = 'download'
      AND (record_count > 100 OR bytes_transferred > 500000000)
ORDER BY timestamp DESC;
```

Checks:

- ☐ Was the `record_type` `PassengerManifest` or `SecurityProtocol`?
- ☐ Is the employee a `SecurityOfficer` or `ITAdmin`? (These roles have authorised access.)
- ☐ If authorised role + single large export → escalate to supervisor to confirm task legitimacy.
- ☐ If unauthorised role (`RampAgent`, `BaggageHandler`, `Mechanic`) → **escalate immediately**.

Step 1.4 — Correlate VPN Unusual Country (if present)

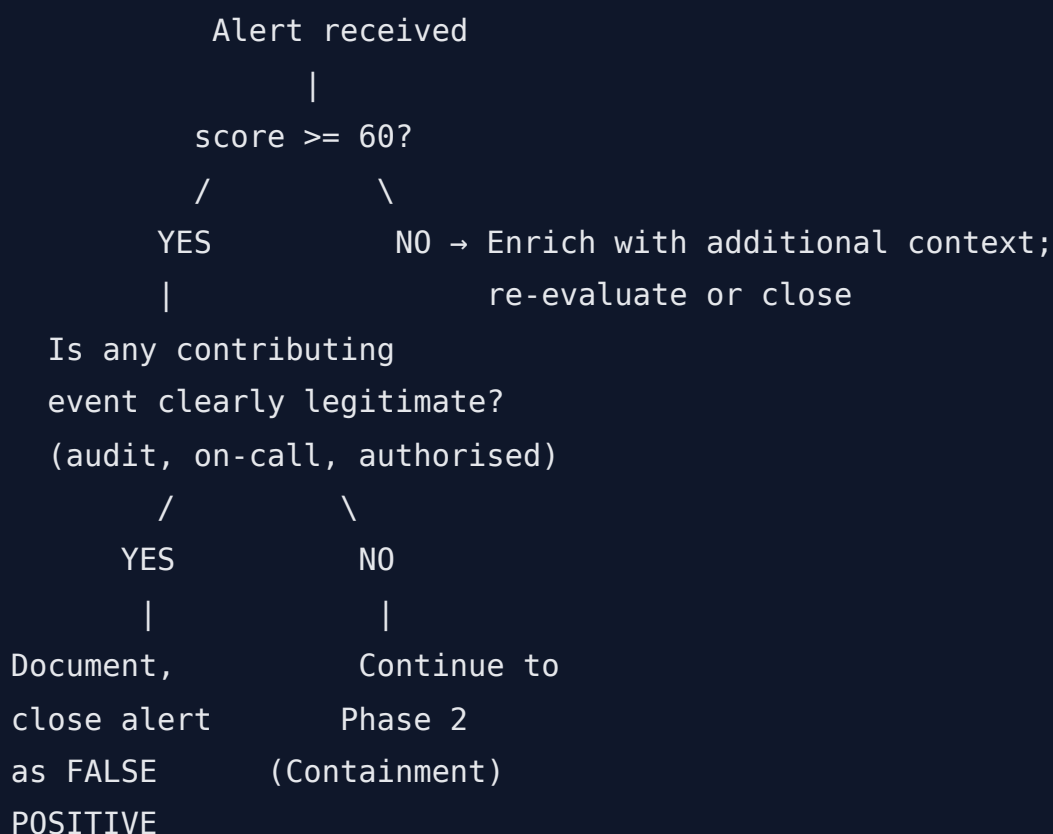
Query the `vpn_logs`:

```
SELECT timestamp, src_ip, geo_country, auth_result
FROM vpn_logs
WHERE username = '<EMP_ID>'
      AND (geo_country IN ('RU','CN','IR','KP','SY') OR geo_country !=
typical_country)
ORDER BY timestamp;
```

Checks:

- ☐ Was there a successful login from a high-risk country?
- ☐ If yes AND combined with badge + download → **credential compromise likely**.
- ☐ If only failed attempts (brute-force pattern with >3 failures in 10 min) → could be password spray.

Step 1.5 — Decision Tree



Triage outcome options:

Outcome	Action	Code
---------	--------	------

Benign / False Positive	Document reason, close alert	FP-001
Suspicious — Low Confidence	Enrich with HR data, monitor for 24 h	SUS-L
Suspicious — High Confidence	Escalate to Containment (Phase 2)	SUS-H
Confirmed Malicious	Escalate to Containment + Legal	MAL

2. Immediate Containment Actions

Goal: Stop the threat from progressing.

Target: 15–30 minutes from escalation.

2.1 — Network Containment

Action	Owner	Details
Disable VPN account	Network Security	Revoke VPN access for <code>username</code> in the <code>aviation_vpn</code> system.
Disable crew portal access	Portal Admin	Set <code>user</code> status to "disabled" in <code>crew_portal_api</code> .
Isolate workstation	IT / Endpoint	If employee is on-site, disconnect network cable; if remote, revoke VPN + force logout.
Revoke badge access	Security Operations	Set <code>granted</code> = False for all doors for the <code>employee_id</code> .

2.2 — Physical Containment

- ☐ Notify **Airport Security Control** to detain the employee if currently on-site.
- ☐ If employee is off-site, document that physical containment will occur upon next arrival.
- ☐ Request guard escort to accompany employee from premises if on-site.

2.3 — Credential Revocation

System	Action
Active Directory / LDAP	Force password reset, disable account.

Email (Exchange / O365)	Revoke active sessions, reset token.
Crew Portal	Disable account + terminate all sessions.
Maintenance System	Revoke technician access (Mechanics only).
VPN Gateway	Revoke all active sessions.

2.4 — Communications (Initial Notification)

Notify the following immediately (within 15 min of containment decision):

Contact	Method	Information to Share
SOC Manager	Phone + Ticket	Alert ID, employee ID, risk score, summary of events.
Legal Department	Encrypted email	Employee details, data types potentially exfiltrated.
HR Director	Phone + email	Employee name, role, shift schedule, any prior HR flags.
Airport Security Director	Phone	Employee location (on-site / off-site), badge status.
Aviation Security Authority (TSA/DHS)	Per regional protocol	Only if threat to flight safety or smuggling suspected.

Sample communication template:

INITIAL INCIDENT NOTIFICATION
Alert ID: IR-2025-06-02-001
Employee: EMP_0019 (Mechanic)
Risk Score: 9931 (HIGH)
Trigger Events: Off-hours badge to MaintenanceHangar + CargoArea (22:00–04:00); bulk download of SecurityProtocol (record_count=51); VPN login from KP (high-risk country).
Containment Status: Badge revoked, VPN disabled, workstation isolated.
Investigating Analyst: [Name] | *SOC Manager:* [Name]

3. Evidence Collection & Forensics

Goal: Preserve all relevant logs and forensic artifacts.

Target: 1–2 hours for log export; forensic imaging as soon as possible (if applicable).

3.1 — Log Preservation

Export the following **raw log data** for the affected employee covering **the last 7 days** (or the full date range of suspicious activity, whichever is longer).

Log Source	Export Fields	Date Range	Retention
Badge Logs	timestamp, employee_id, door_location, granted	7 days	90 days
VPN Logs	timestamp, username, src_ip, auth_result, geo_country	7 days	90 days
Crew Portal Logs	timestamp, user, action, record_type, record_count, bytes_transferred	7 days	90 days
Maintenance Logs	timestamp, technician_id, action, component, status, work_order_valid	7 days	1 year (safety)
Cargo Logs	timestamp, handler_id, cargo_id, action, weight_kg	7 days	90 days

Export format: CSV with SHA-256 hash of the file. Store in `evidence/<Alert_ID>/`.

3.2 — Employee Table Snapshot

Export a snapshot of the employee's current record from `employee_table.csv`:

- `employee_id`, `name`, `role`, `shift_start`, `shift_end`, `termination_date`
- Note: If `termination_date` falls before the events, this is a **critical finding** — terminated employees should not have badge or system access.

3.3 — Workstation Forensics (if available)

If the employee has a workstation and it has not been powered off:

- ☐ Capture live memory (RAM) using a tool such as `FTK Imager` or `Magnet RAM Capture`.

- ☐ Capture disk image (bit-for-bit) to an external drive — follow local forensic procedures.
- ☐ Record USB device history:
 - Windows: `%SystemRoot%\setupapi.dev.log` , USBStor registry key.
 - Linux: `/var/log/syslog` , `dmesg` , `usb-devices` .
- ☐ Note any external storage or personal devices connected.

3.4 — Chain of Custody

Document the following for every piece of evidence:

```
EVIDENCE ID:      EV-<Alert_ID>-001
DESCRIPTION:      Badge logs export for EMP_0019, 2025-05-25 to 2025-05-30
SOURCE:           badge_logs.csv (database export)
TIMESTAMP:        2025-06-02 16:30 UTC
EXPORTED BY:      [Analyst Name]
HASH (SHA-256):   a3f5b8c1d2e4f6a8b0c2d4e6f8a0b2c4d6e8f0a2b4c6d8e0a2b4c6d8e0a2b4
HANDED TO:        [Forensic Lead Name] on 2025-06-02 17:00 UTC
```

4. Investigation & Analysis

Goal: Determine intent, accomplices, and impact.

Target: 4–8 hours (depending on data volume).

4.1 — Intent Assessment

Use the employee table and HR records (simulated) to assess motive:

Indicator	Possible Intent
Recent termination date or pending notice	Retaliation / sabotage
Access to high-risk country VPN	Foreign intelligence / coercion
Download of PassengerManifest (PII)	Financial gain (sell PII on dark web)
Download of SecurityProtocol	Espionage / sabotage planning

Cargo weight manipulation	Theft / smuggling
Maintenance tampering (override_sensor)	Sabotage / operational disruption

4.2 — Accomplice Detection

Correlate badge logs to identify if the employee tailgated with others:

- Query badge_logs for the **same door within 60 seconds** of the employee's access.
- If another employee's badge was used at the same door within 60 s → possible tailgating.
- If multiple employees from the same role are showing similar patterns → **collusion investigation**.

4.3 — Data Exfiltration Analysis

Analyse what specific data was downloaded and whether it left the network:

Check	Data Source	Action
Which record IDs were downloaded?	crew_portal_logs (detail field)	Identify specific manifests / protocols.
Was data emailed externally?	Email logs (if integrated)	Search for attachments to non-company domains.
Was data uploaded to cloud storage?	Web proxy logs (if available)	Check for uploads to Dropbox, Google Drive, etc.
Was a USB device connected?	Workstation forensics	Check USB history for large file transfers.

4.4 — Safety Impact Assessment

For **Mechanics** or **ITAdmin** with maintenance tampering events:

- Has the employee accessed aircraft systems (`aircraft_id` in maintenance_logs)?
- Was a sensor overridden or alarm disabled on an active aircraft?
- If yes → contact **Maintenance Control** immediately to inspect the affected aircraft before next flight.
- Cross-reference with `work_order_valid` : if False, no authorised maintenance — treat as active sabotage.

5. Escalation & Notification

Goal: Ensure the right stakeholders are informed at the right time.

Timing: Parallel with containment and investigation.

5.1 — Internal Escalation (Mandatory)

Trigger	Contact	When
Any SUS-H or MAL	SOC Manager	Immediately (within 15 min)
PII potentially exfiltrated (PassengerManifest)	Legal + DPO	Within 1 hour
Payment or financial data involved	CFO / Finance	Within 1 hour
Employee with active grievances	HR Director	Within 1 hour
Threat to flight safety	Aviation Security Director	Immediately

5.2 — External Escalation (As Needed)

Situation	Agency	Contact
Smuggling / theft	TSA / DHS	[Insert local TSA field office]
Terrorism / espionage	FBI Joint Terrorism Task Force	[Insert local FBI field office]
Data breach (GDPR)	Supervisory Authority	Notify within 72 h of discovery
Data breach (CCPA)	California AG	Notify without unreasonable delay

5.3 — Affected Party Notification

- If PassengerManifest data was exfiltrated → consult Legal on whether individual notification is required.
 - If flight operations were impacted → notify affected airline partners and passengers.
-

6. Remediation & Recovery

Goal: Restore normal operations and prevent recurrence.

Target: 1–5 business days.

6.1 — Remove Malicious Access

- ☐ Verify that all credentials for the employee have been revoked.
- ☐ Check for backdoors: Review maintenance_logs for `install_software` with `source = "USB"` — any installed binaries must be removed.
- ☐ Rotate any shared secrets the employee had access to.

6.2 — Patch Vulnerabilities Exploited

- If the bulk download exploited an API weakness → file a change request to apply rate-limiting and anomaly detection.
- If VPN access was via stolen credentials → enforce MFA on all VPN accounts (if not already enabled).
- If badge access was via cloned badge → upgrade to anti-passback / biometric readers on high-security doors.

6.3 — Enhanced Monitoring (30 Days)

Deploy the following monitoring on the employee's department / peer group:

Rule	Scope	Duration
Off-hours badge to sensitive doors	All roles in same department	30 days
Bulk download of SecurityProtocol	All roles except SecurityOfficer	30 days
VPN login from unusual country	All employees	30 days
Cargo weight delta > 20 kg	All cargo handlers	30 days

6.4 — Lessons Learned

Conduct a post-incident review within 10 business days. Agenda:

1. Timeline: Review detection → containment → eradication → recovery.
2. Gaps: Were any detection rules missing or too slow?

- 3. Tuning: Adjust Sigma rule thresholds (e.g., lower `bytes_transferred` threshold from 500 MB to 200 MB).
- 4. Training: Did the employee bypass a control that requires procedural (not technical) change?
- 5. Documentation: Update this playbook with any new insights.

7. Appendices

Appendix A — Incident Ticket Template

Use the following fields in the SIEM ticketing system (e.g., TheHive, ServiceNow).

Field	Value
Ticket ID	IR - <YYYY-MM-DD> - <SEQ>
Alert ID	(from SIEM)
Title	High-Risk Insider: <employee_id> (<role>)
Status	New / In Triage / Contained / Investigating / Remediating / Closed
Severity	Critical / High / Medium / Low
Employee ID	
Employee Role	
Risk Score	
Triggering Events	(list of event_type with weights)
Triage Outcome	Benign / Suspicious-Low / Suspicious-High / Malicious
Containment Actions	(badge revoked, VPN disabled, etc.)
Evidence Exported	(list of file hashes)
Forensic Findings	
HR Flags	(grievance, termination notice, etc.)

Legal Referral	Yes / No
Root Cause	
Closure Notes	
Closure Date	

Appendix B — Internal Escalation Contact List

Role	Name (placeholder)	Phone	Email
SOC Manager	[SOC Manager Name]	[Phone]	[Email]
SOC Deputy Manager	[Deputy Name]	[Phone]	[Email]
Legal Counsel (IT/IP)	[Legal Name]	[Phone]	[Email]
HR Director	[HR Name]	[Phone]	[Email]
Airport Security Director	[Security Director Name]	[Phone]	[Email]
Aviation Security Authority	TSA Field Office	[Insert TSA contact]	[Insert TSA email]
CISO	[CISO Name]	[Phone]	[Email]

Appendix C — High-Risk Insider Incident Checklist

Triage (≤ 15 min)

- ☐ Open alert and record Alert ID, employee ID, role, risk score.
- ☐ Verify off-hours badge access — sensitive door + unscheduled.
- ☐ Verify bulk download — record_type, record_count, bytes_transferred.
- ☐ Correlate VPN unusual country (if present).
- ☐ Determine triage outcome (Benign / SUS-L / SUS-H / MAL).

Containment (≤ 30 min)

- ☐ Revoke badge access.

- ☐ Disable VPN account.
- ☐ Disable crew portal account.
- ☐ Isolate workstation.
- ☐ Force password reset.
- ☐ Notify SOC Manager.
- ☐ Notify Airport Security (if employee on-site).
- ☐ Notify Legal / HR.

Evidence Collection (≤ 2 h)

- ☐ Export badge_logs (7 days).
- ☐ Export vpn_logs (7 days).
- ☐ Export crew_portal_logs (7 days).
- ☐ Export maintenance_logs (7 days) if applicable.
- ☐ Export cargo_logs (7 days) if applicable.
- ☐ Compute SHA-256 hashes.
- ☐ Log chain of custody.

Investigation (≤ 8 h)

- ☐ Assess intent — check termination date, HR flags, VPN country.
- ☐ Check for accomplices — tailgating correlation.
- ☐ Analyse data exfiltration path.
- ☐ Assess safety impact — aircraft access, maintenance tampering.

Remediation (≤ 5 business days)

- ☐ Remove all access / backdoors.
- ☐ Patch vulnerabilities.
- ☐ Notify affected parties.
- ☐ Deploy enhanced monitoring for 30 days.
- ☐ Schedule lessons-learned meeting.